

Mapeo regla → vulnerabilidad / CVE (reglas de frameworks)

15 reglas escritas de forma **independiente** (sin partir del código de ninguna regla de terceros) para cubrir, por frameworks concretos, clases de vulnerabilidad con impacto real demostrado en CVEs conocidos. Sustituyen — sin problema de licencia — a una parte del valor que aportaban las 553 reglas del registro oficial de Semgrep (que no se pueden redistribuir, ver [README.md](#)).

Regla	Framework	Vulnerabilidad	CWE	CVE / incidente real de referencia
django-mark-safe-xss	Django	XSS por desactivar el auto-escapeado de plantillas	CWE-79	Clase recurrente en CVEs de Django/paquetes del ecosistema que usan mark_safe() sobre contenido de usuario
django-extra-raw-sql-injection	Django	Inyección SQL vía QuerySet.extra()/Model.objects.raw()	CWE-89	Motivo por el que Django recomienda explícitamente params= en su documentación de seguridad
django-debug-true-production	Django	Exposición de información por DEBUG=True en producción	CWE-215	Misconfiguración recurrente en informes de bug bounty y brechas reales; páginas de traceback de Django exponen código fuente y variables
flask-render-template-string-ssti	Flask / Jinja2	Server-Side Template Injection → RCE	CWE-1336	Clase de vulnerabilidad documentada extensamente por PortSwigger/OWASP; mismo patrón que CVE-2019-8341 (Ghost CMS SSTI)

Regla	Framework	Vulnerabilidad	CWE	CVE / incidente real de referencia
<code>flask-pickle-session-deserialization</code>	Flask	Deserialización insegura de sesión → RCE	CWE-502	Mismo mecanismo que backdoors conocidos en Flask/Django cuando se sustituye el serializador de sesión por pickle
<code>express-child-process-exec-injection</code>	Express / Node.js	Inyección de comandos OS vía <code>child_process.exec()</code>	CWE-78	Clase de vulnerabilidad presente en decenas de CVEs de paquetes npm (ver GitHub Advisory Database, búsqueda "child_process.exec")
<code>express-eval-dynamic-code</code>	Express / Node.js	RCE vía <code>eval()/new Function()</code> sobre input de red	CWE-95	Vector clásico en CVEs de paquetes npm con "prototype pollution to RCE" o "unsafe eval"
<code>express-cors-wildcard-credentials</code>	Express	CSRF-adyacente: CORS con origin reflejado + credentials	CWE-942	Configuración de alto riesgo documentada por el propio middleware <code>cors</code> como anti-patrón
<code>spring-spel-injection</code>	Spring	RCE vía inyección de Spring Expression Language (SpEL)	CWE-917	CVE-2022-22963 (Spring Cloud Function SpEL RCE), CVE-2018-1273 (Spring Data Commons)
<code>spring-jpa-query-injection</code>	Spring / JPA	Inyección SQL/JPQL vía <code>createQuery()/createNativeQuery()</code>	CWE-89	Clase de vulnerabilidad cubierta en la guía oficial de Spring Data JPA sobre parámetros con nombre

Regla	Framework	Vulnerabilidad	CWE	CVE / incidente real de referencia
spring-actuator-exposed-endpoints	Spring Boot	Exposición de información vía Actuator (/env , /heapdump)	CWE-200	Misconfiguración de alto perfil en múltiples informes de bug bounty/breach reports reales de Spring Boot en producción
rails-render-inline-ssti	Ruby on Rails	Server-Side Template Injection (ERB) → RCE	CWE-1336	Documentado por Trail of Bits (referencia en la propia regla) como vector de RCE en Rails
rails-mass-assignment-permit-bang	Ruby on Rails	Mass assignment sin control vía permit!	CWE-915	Vulnerabilidad de GitHub de 2012 (mass assignment de clave pública SSH) que motivó la introducción de Strong Parameters en Rails
java-log4j-unsanitized-input	Java / Log4j	Log injection / vector de Log4Shell	CWE-117	CVE-2021-44228 (Log4Shell) — una de las vulnerabilidades más críticas y explotadas de 2021-2022
spring-file-upload-no-validation	Spring	Subida de fichero sin restricción → RCE	CWE-434	Clase clásica de "unrestricted file upload", documentada extensamente por OWASP

Nota de independencia legal

Estas reglas se diseñaron a partir del conocimiento general de cada CWE/CVE (documentación oficial de cada framework, avisos NVD/CISA, OWASP), **no leyendo ni adaptando el código de ninguna regla existente de terceros**. Esto las diferencia de una "copia modificada" (que seguiría bajo la licencia del original) y permite incluirlas en [custom/](#) sin restricción de redistribución — a diferencia de las 553 reglas del registro oficial de Semgrep, que sí están cubiertas por la Semgrep Rules License v1.0 y no pueden mezclarse aquí. Ver [.claude/README.md](#) para el detalle completo del problema de licencias.